

Лабораторная работа №2

Кибербезопасность предприятия

Еюбоглу Т, Зиязетдинов А, Исаев Б| НПИбд-01-22

Содержание

1	Цель работы	4
2	Теоретическое введение	5
3	Выполнение лабораторной работы	6
3.0.1	2.1 Уязвимость CVE-2020-24186 в WpDiscuz	6
3.0.2	2.2 Proxylogon (CVE 2021-26855 (SSRF))	14
4	Вывод	22
5	Список литературы	23

Список иллюстраций

3.1	ViPNet IDS NS	7
3.2	Вход в панель администратора	8
3.3	Отключение плагина в панели управления в WordPres	9
3.4	Страница сайта	10
3.5	Существующие резервные копии UpdraftPlus	11
3.6	Успешное выполнение восстановления	12
3.7	Отображение информации о TCP-соединениях	13
3.8	Процесс закрытия meterpreter-сессии	14
3.9	IP Address and Domain Restrictions.	16
3.10	Завершение процессов.	16
3.11	Удаление файла AM BACKDOOR.	17
3.12	Восстановление пароля	18
3.13	Ссылка для сброса пароля	19
3.14	back_up коды для двух. аутентификации	20
3.15	Настройка конфигурации БД	21
3.16	Удаление соединений	21

1 Цель работы

Изучить сценарий атаки внешнего злоумышленника на корпоративную инфраструктуру с использованием уязвимостей в компонентах веб-серверов, почтовых систем и мессенджеров. Освоить методы обнаружения, анализа и устранения последствий компьютерных атак с использованием программного комплекса Empire, включая выявление уязвимостей (CVE-2020-24186, CVE-2021-22911, CVE-2022-0847, CVE-2020-26855 и CVE-2021-27065), а также нейтрализацию их последствий.

2 Теоретическое введение

Внешний злоумышленник проводит многоэтапную атаку на корпоративную инфраструктуру, начиная с эксплуатации уязвимостей на публичных сервисах (веб-сайт, почтовый сервер, мессенджер). Цель атаки — получение контроля над внутренними ресурсами, захват контроллера домена, хищение данных и деградация работы компании. Для этого используются следующие уязвимости:

CVE-2020-24186 (WpDiscuz): удалённое выполнение кода (RCE) через загрузку PHP-файла в комментариях.

CVE-2021-22911 и CVE-2022-0847 (Rocket.Chat): NoSQL-инъекция и уязвимость Dirty Pipe для повышения привилегий.

CVE-2020-26855 и CVE-2021-27065 (Proxylogon): обход аутентификации в Exchange Server и запись файла в произвольную директорию.

Последствия атак включают: дефейс сайта, установку обратных оболочек (meterpreter), создание backdoor, шифрование файлов, добавление пользователей и др.

Для защиты применяются системы мониторинга (ViPNet IDS NS, Security Onion), анализ логов, обновление ПО, настройка политик безопасности.

3 Выполнение лабораторной работы

3.0.1 2.1 Уязвимость CVE-2020-24186 в WpDiscuz

Условия эксплуатации: Версия плагина WpDiscuz 7.0.2, доступ к веб-серверу WordPress.

Шаги атаки:

Нарушитель отправляет POST-запрос на `/wp-admin/admin-ajax.php` с загрузкой PHP-файла через поле комментариев.

Файл сохраняется на сервере и позволяет выполнить произвольный код.

Обнаружение:

В логах Apache (`/var/log/apache2/access.log`) появляются запросы к `admin-ajax.php` с загрузкой файлов.

В журнале активности WordPress фиксируется несанкционированное действие.

Сенсоры VipNet IDS NS и Security Onion детектируют аномальные запросы (например, `ET WEB_SERVER PHP tags in HTTP POST`). (рис. 3.1)

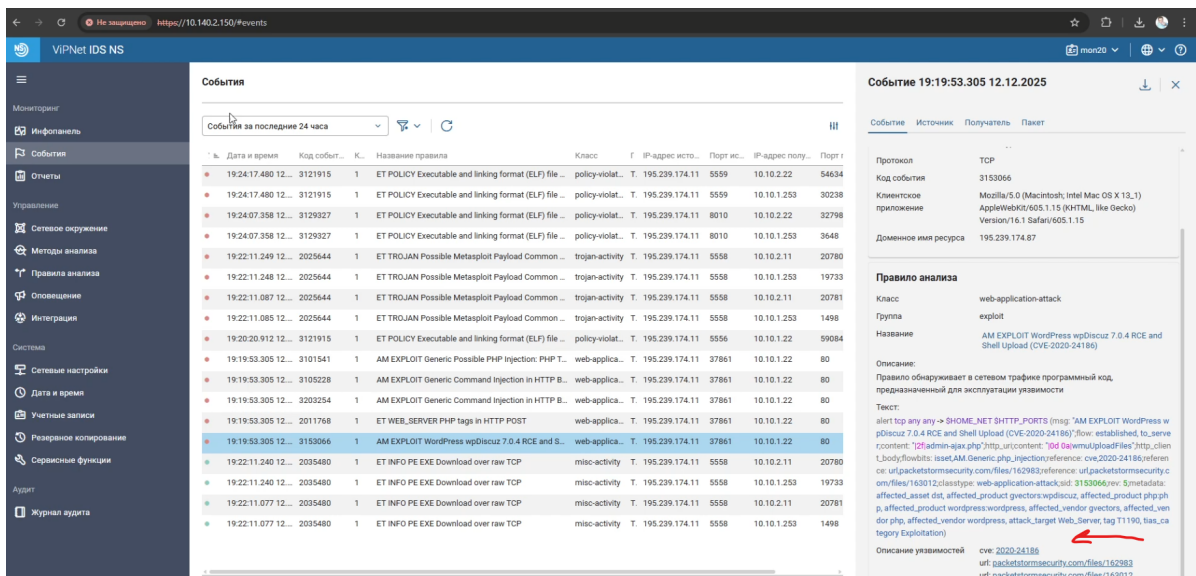


Рис. 3.1: ViPNet IDS NS

Устранение уязвимости:

Отключение плагина: В панели управления WordPress ☒ Plugins ☒ Deactivate (или Delete) для WpDiscuz. (рис. 3.2) (рис. 3.3)

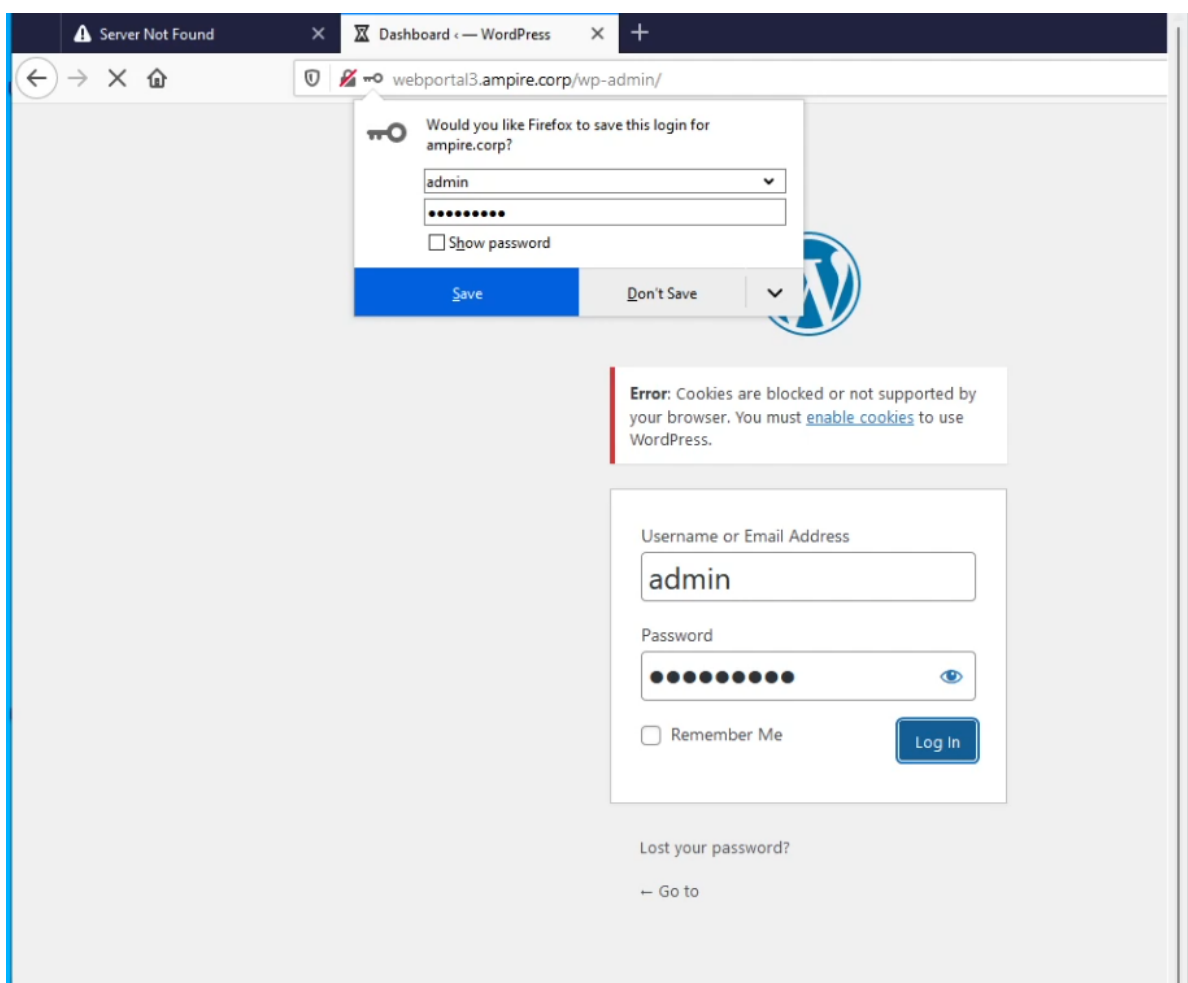


Рис. 3.2: Вход в панель администратора

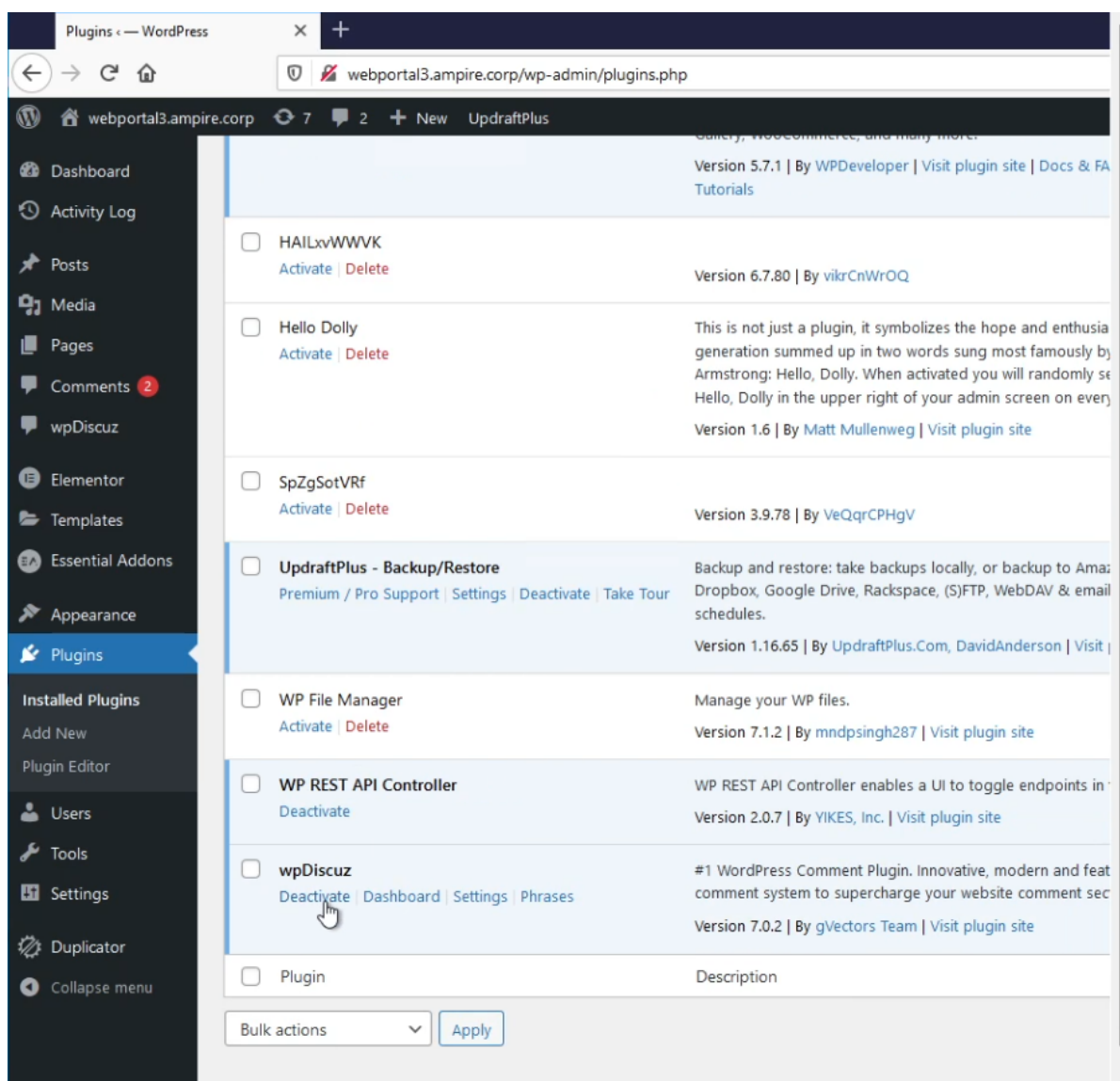


Рис. 3.3: Отключение плагина в панели управления в WordPress

Обновление плагина: Загружена версия 7.0.5 (или выше) через раздел Plugins
 ✕ Add New ✕ Upload Plugin.

Нейтрализация последствий:

Дефейс сайта: восстановление из резервной копии через плагин UpdraftPlus.
 (рис. 3.4) (рис. 3.5) (рис. 3.6) (рис. 3.7) (рис. 3.8)

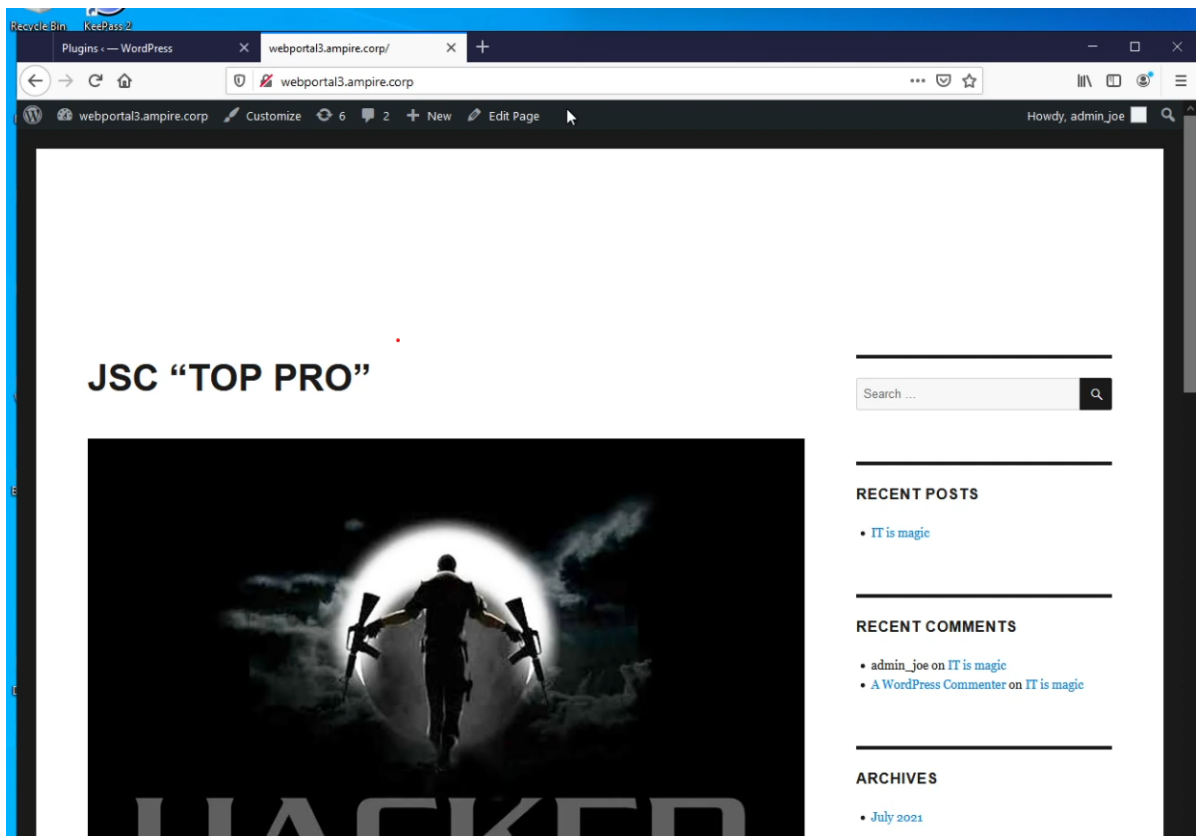


Рис. 3.4: Страница сайта

UpdraftPlus Backup/Restore



WP-Optimize

After you've backed up your database, we recommend you install our WP-Optimize plugin to streamline it for better website performance. [Read more](#)

[UpdraftPlus.Com](#) | [Premium](#) | [News](#) | [Twitter](#) | [Support](#) | [Newsletter sign-up](#) | [Lead developer's homepage](#) | [FAQs](#) | [More plugins](#) - Version: 1.16.65

Backup / Restore

Migrate / Clone

Settings

Advanced Tools

Premium / Extensions

Warning: WordPress has a number (27) of scheduled tasks which are overdue. Unless this is a development site, this probably means that the scheduler in your WordPress install is not working. [Read this](#)

Next scheduled backups:

Files:

Nothing currently scheduled

Time now: Sat, December 13, 2025 17:41

Database:

Nothing currently scheduled

Last log message:

The backup apparently succeeded and is now complete (Sep 15 08:49:23)

Existing backups 3

More tasks: [Upload backup files](#) | [Rescan local folder for new backup sets](#) | [Rescan remote storage](#)

☐	Backup date	Backup data (click to download)
☐	Sep 15, 2023 8:49	DatabasePluginsThemesUploadsOthers
☐	Jul 27, 2023 9:26	DatabasePluginsThemesUploadsOthers
☐	Nov 30, 2021 9:37	DatabasePluginsThemesUploadsOthers

Рис. 3.5: Существующие резервные копии UpdraftPlus

11

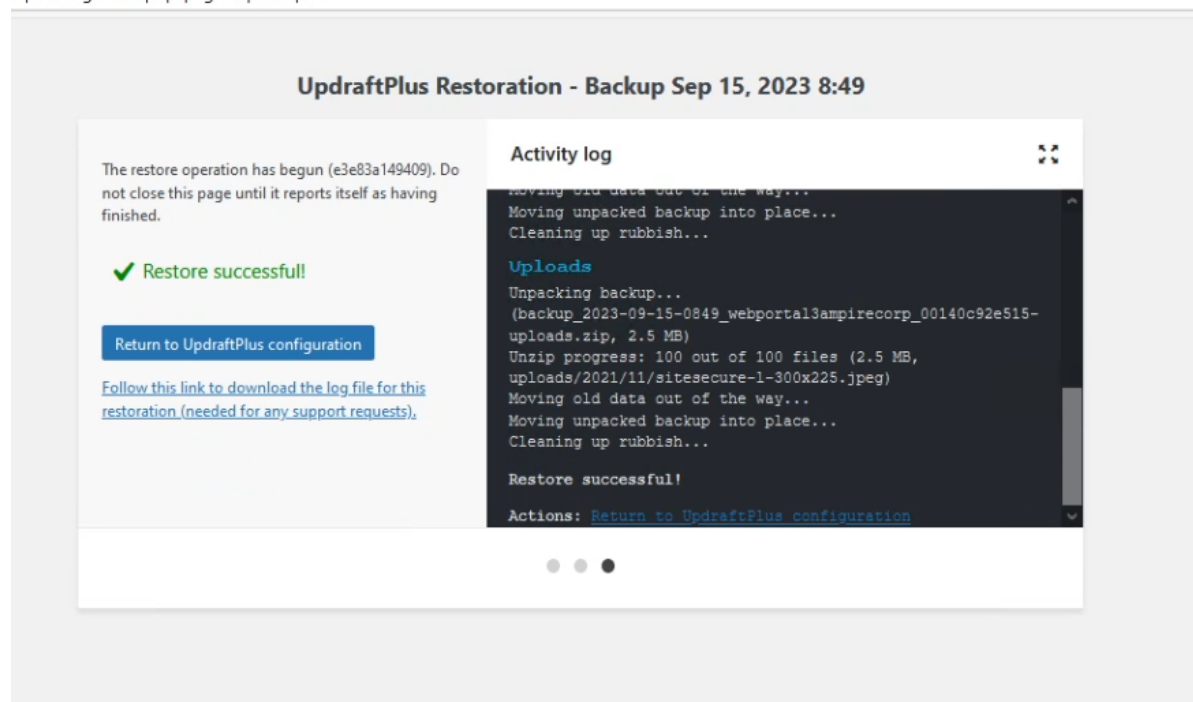


Рис. 3.6: Успешное выполнение восстановления

Meterpreter-сессия: завершение процесса Apache, связанного с вредоносным сокетом (команда kill).

```
root@web-portal-3: ~  
user@web-portal-3:~$  
user@web-portal-3:~$  
user@web-portal-3:~$  
user@web-portal-3:~$ root  
Command 'root' not found, but can be installed with:  
  
sudo snap install root-framework  
  
user@web-portal-3:~$ sudo  
usage: sudo -h | -K | -k | -V  
usage: sudo -v [-AknS] [-g group] [-h host] [-p prompt] [-u user]  
usage: sudo -l [-AknS] [-g group] [-h host] [-p prompt] [-U user] [-u user]  
[command]  
usage: sudo [-AbEHknPS] [-r role] [-t type] [-C num] [-g group] [-h host] [-p  
prompt] [-T timeout] [-u user] [VAR=value] [-i|-s] [<command>]  
usage: sudo -e [-AknS] [-r role] [-t type] [-C num] [-g group] [-h host] [-p  
prompt] [-T timeout] [-u user] file ...  
user@web-portal-3:~$ sudo -i  
[sudo] password for user:  
root@web-portal-3:~# sudo ss =tnp  
Error: an inet prefix is expected rather than "=tnp".  
Cannot parse dst/src address.  
root@web-portal-3:~# sudo ss -tnp  
State      Recv-Q    Send-Q      Local Address:Port      Peer Address:Port  
CLOSE-WAIT 1          0          10.10.1.22:46314        195.239.174.11:5557  
users: (("chisel.sh",pid=3330,fd=12), ("sh",pid=3329,fd=12), ("BKenU",pid=3307,fd=12))  
ESTAB      0          0          10.10.1.22:59084        195.239.174.11:5556  
users: (("chisel.sh",pid=3330,fd=3), ("sh",pid=3329,fd=3), ("BKenU",pid=3307,fd=3))  
SYN-SENT   0          1          10.10.1.22:47220        195.239.174.125:8140  
users: (("puppet",pid=25653,fd=6))  
ESTAB      0          64          10.10.1.22:22           10.10.1.253:32137  
users: (("sshd",pid=25884,fd=3), ("sshd",pid=25746,fd=3))  
ESTAB      0          0          10.10.1.22:55860        195.239.174.11:1085  
users: (("chisel.sh",pid=3330,fd=11))  
FIN-WAIT-2 0          0          10.10.1.22:41750        10.10.2.11:443  
users: (("chisel.sh",pid=3330,fd=16))  
root@web-portal-3:~#
```

Рис. 3.7: Отображение информации о ТСР-соединениях

State	Recv-Q	Send-Q	Local Address:Port	Peer Address:Port
ESTAB	0	0	10.10.1.22:22	10.10.1.253:17105
users: (("sshd",pid=5323,fd=3), ("sshd",pid=5255,fd=3))				
FIN-WAIT-2	0	0	10.10.1.22:38580	10.10.2.11:443
users: (("chisel.sh",pid=1863,fd=16))				
ESTAB	0	0	10.10.1.22:59624	195.239.174.11:5556
users: (("chisel.sh",pid=1863,fd=3), ("sh",pid=1862,fd=3), ("jIwcT",pid=1841,fd=3))				
ESTAB	0	0	10.10.1.22:51944	195.239.174.11:1085
users: (("chisel.sh",pid=1863,fd=11))				
ESTAB	0	64	10.10.1.22:22	10.10.1.253:64405
users: (("sshd",pid=5028,fd=3), ("sshd",pid=4887,fd=3))				
CLOSE-WAIT	0	0	10.10.1.22:60796	195.239.174.11:5557
users: (("chisel.sh",pid=1863,fd=12), ("sh",pid=1862,fd=12), ("jIwcT",pid=1841,fd=12))				
root@web-portal-3:~# kill 1863				
root@web-portal-3:~# sudo ss -tnp				
State	Recv-Q	Send-Q	Local Address:Port	Peer Address:Port
FIN-WAIT-2	0	0	10.10.1.22:38580	10.10.2.11:443
ESTAB	0	0	10.10.1.22:59624	195.239.174.11:5556
users: (("jIwcT",pid=1841,fd=3))				
ESTAB	0	64	10.10.1.22:22	10.10.1.253:64405
users: (("sshd",pid=5028,fd=3), ("sshd",pid=4887,fd=3))				
CLOSE-WAIT	0	0	10.10.1.22:60796	195.239.174.11:5557

Рис. 3.8: Процесс закрытия meterpreter-сессии

Caidao PHP backdoor: удаление файла caidao.php из директории /var/www/html/wordpress/.

3.0.2 2.2 Proxylogon (CVE 2021-26855 (SSRF))

CVE-2021-26855, также известная как Proxylogon, представляет собой уязвимость типа Server-Side Request Forgery (SSRF) в Microsoft Exchange Server. Данная уязвимость позволяет злоумышленнику обходить аутентификацию и выполнять запросы от имени сервера к внутренним ресурсам, что в итоге приводит к получению несанкционированного доступа к почтовым ящикам и выполнению произвольного кода.

Условия эксплуатации:

Наличие доступа к веб-интерфейсу Exchange (ECP) по адресу <https://ecp>.

Знание действительного email-адреса пользователя на атакуемом сервере.

Уязвимые версии Exchange Server (до версии 15.01.2106.013).

Шаги атаки:

Обход аутентификации через SSRF: Злоумышленник отправляет специально сформированный запрос к конечной точке /autodiscover/autodiscover.xml, используя поддельный заголовок X-BEResource, который указывает на внутренний

URL сервера. Это позволяет получить LegacyDN целевого пользователя.

Получение SID пользователя: Используя полученный LegacyDN, атакующий отправляет POST-запрос к /ecp/.js, что приводит к ошибке доступа, в ответе которой содержится SID (Security Identifier) пользователя.

Авторизация в системе: С помощью полученного SID злоумышленник отправляет запрос на авторизацию в Outlook, получая в ответ cookies (ASP.NET_SessionID и msExchEcpCanary), необходимые для дальнейших действий.

Использование CVE-2021-27065: После успешной авторизации атакующий может изменить параметры виртуальной директории OAB (Offline Address Book) в панели управления Exchange, что позволяет записать вредоносный файл (например, веб-шелл) в произвольную директорию сервера.

Устранение уязвимости:

Во время эксплуатации уязвимости Proxylogon злоумышленник выполняет GET- и POST-запросы к директории /ecp на сервере Exchange. Для предотвращения эксплуатации уязвимости достаточно ограничить доступ к этой директории. Ниже приведены рекомендации по устранению уязвимости:

Открытие Internet Information Services (IIS) Manager: Нажмите сочетание клавиш Win + R, в появившемся окне введите inetmgr и нажмите Enter.

Настройка ограничений доступа: В открывшемся окне IIS Manager перейдите во вкладку: MAIL ☒ Sites ☒ Default Web Site ☒ ecp. Выберите пункт IP Address and Domain Restrictions. (рис. 3.9)

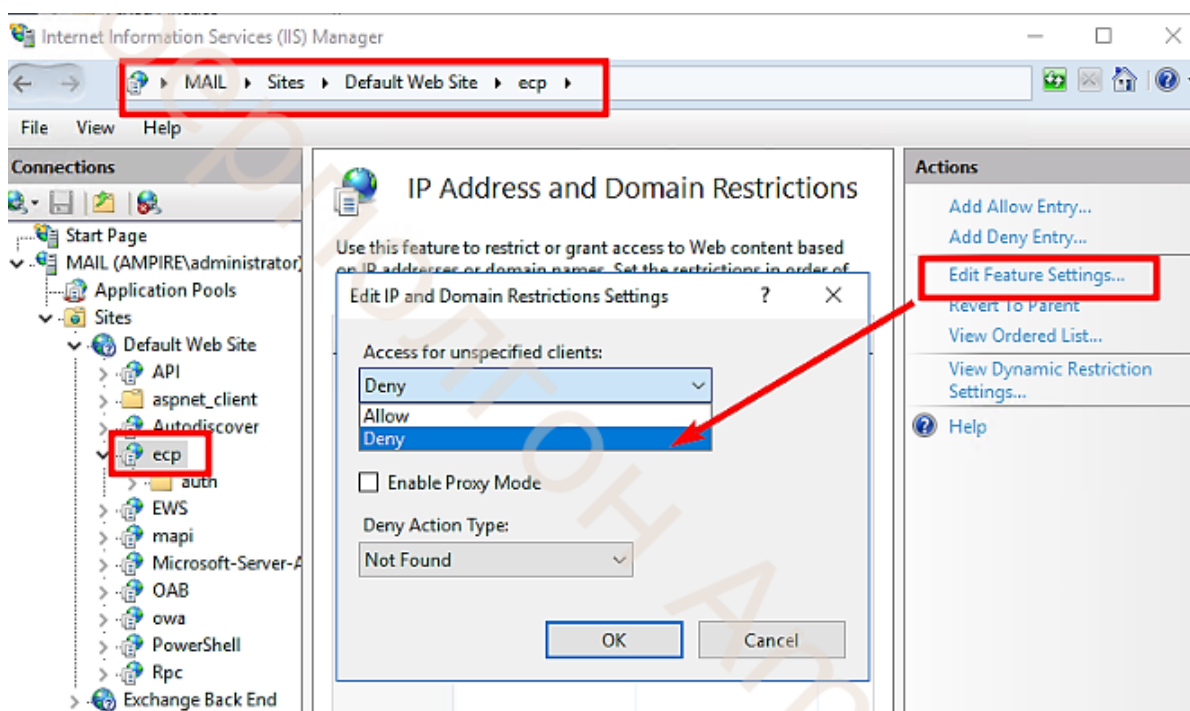


Рис. 3.9: IP Address and Domain Restrictions.

Обнаружение и устранение полезной нагрузки China Chopper и Meterpreter Сессии

Для устранения полезной нагрузки «meterpreter-сессия» необходимо: 1. Выполнить команду `netstat -b -o` для обнаружения активных соединений. 2. С помощью команды `taskkill /PID /F` завершить процессы, устанавливающие соединение с хостом нарушителя. (рис. 3.10)

```
[msexchangepl.exe]
C:\Users\administrator.AMPIRE>taskkill /PID 2108 /F
SUCCESS: The process with PID 2108 has been terminated.
C:\Users\administrator.AMPIRE>taskkill /PID 2108_ /F
```

Рис. 3.10: Завершение процессов.

Устранение полезной нагрузки “Web-shell China Chopper”

Для нейтрализации данного последствия атаки необходимо выполнить следующие действия:

Удаление файла веб-оболочки:

Завершение вредоносных сетевых соединений: Обнаружить и принудительно завершить все установленные злоумышленником соединения между скомпрометированным сервером и внешним хостом. Подробная процедура описана в Подразделе 4.1 (методы завершения meterpreter-сессий).

Примечание: Оба шага являются обязательными для полной нейтрализации угрозы. Удаление файла предотвращает повторный доступ, а завершение соединений останавливает активное взаимодействие злоумышленника с системой. (рис. 3.11)

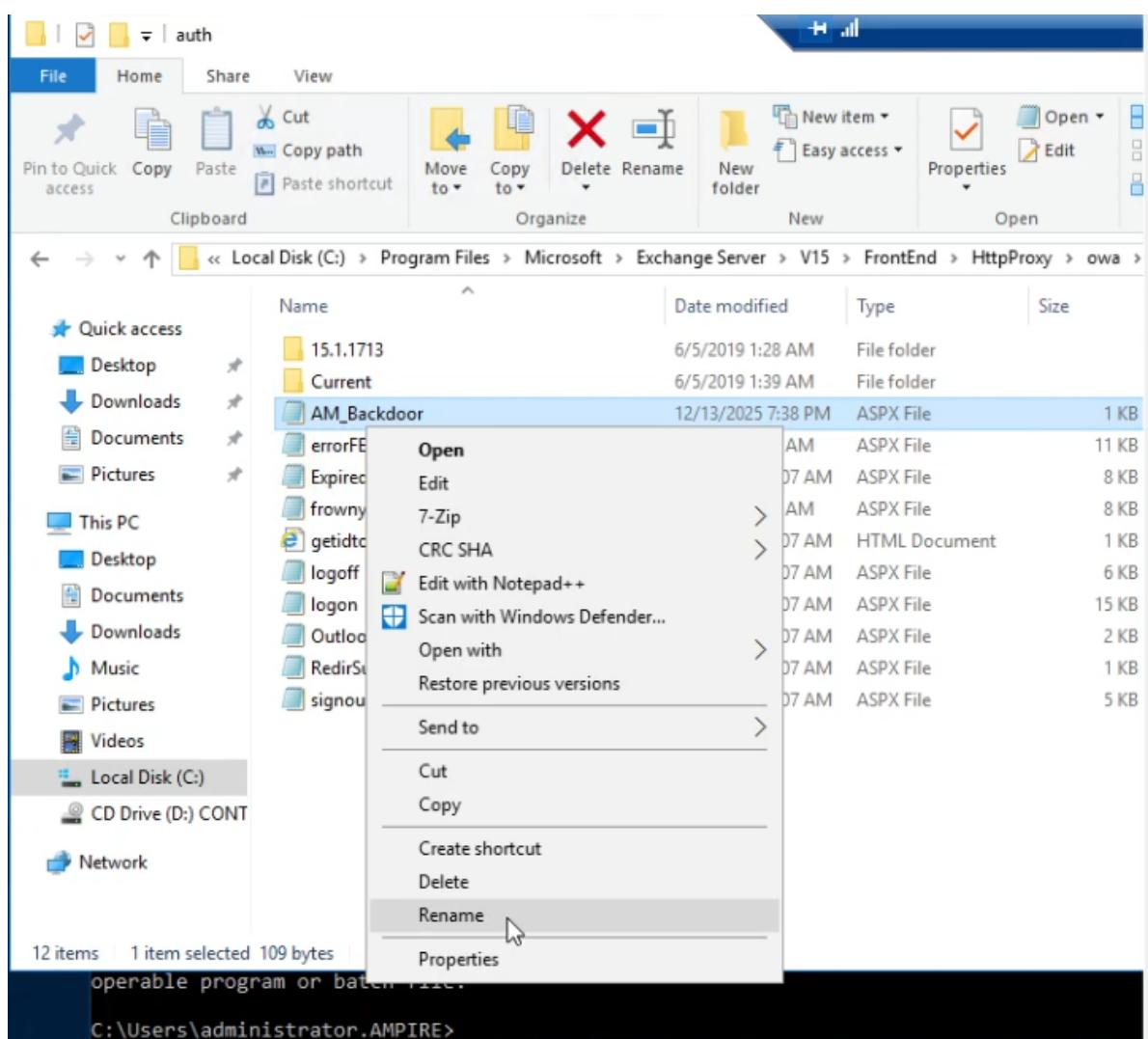


Рис. 3.11: Удаление файла AM BACKDOOR.

Закрытие уязвимостей в Rocket Chat Для восстановления доступа к аккаунту администратора необходимо сбросить пароль. Письмо с инструкциями для сброса пароля можно прочитать при помощи утилиты mail (переключившись на учетную запись admin), либо при помощи текстового редактора, прочитав файл /var/mail/admin (рис. 3.12) (рис. 3.13) (рис. 3.14):

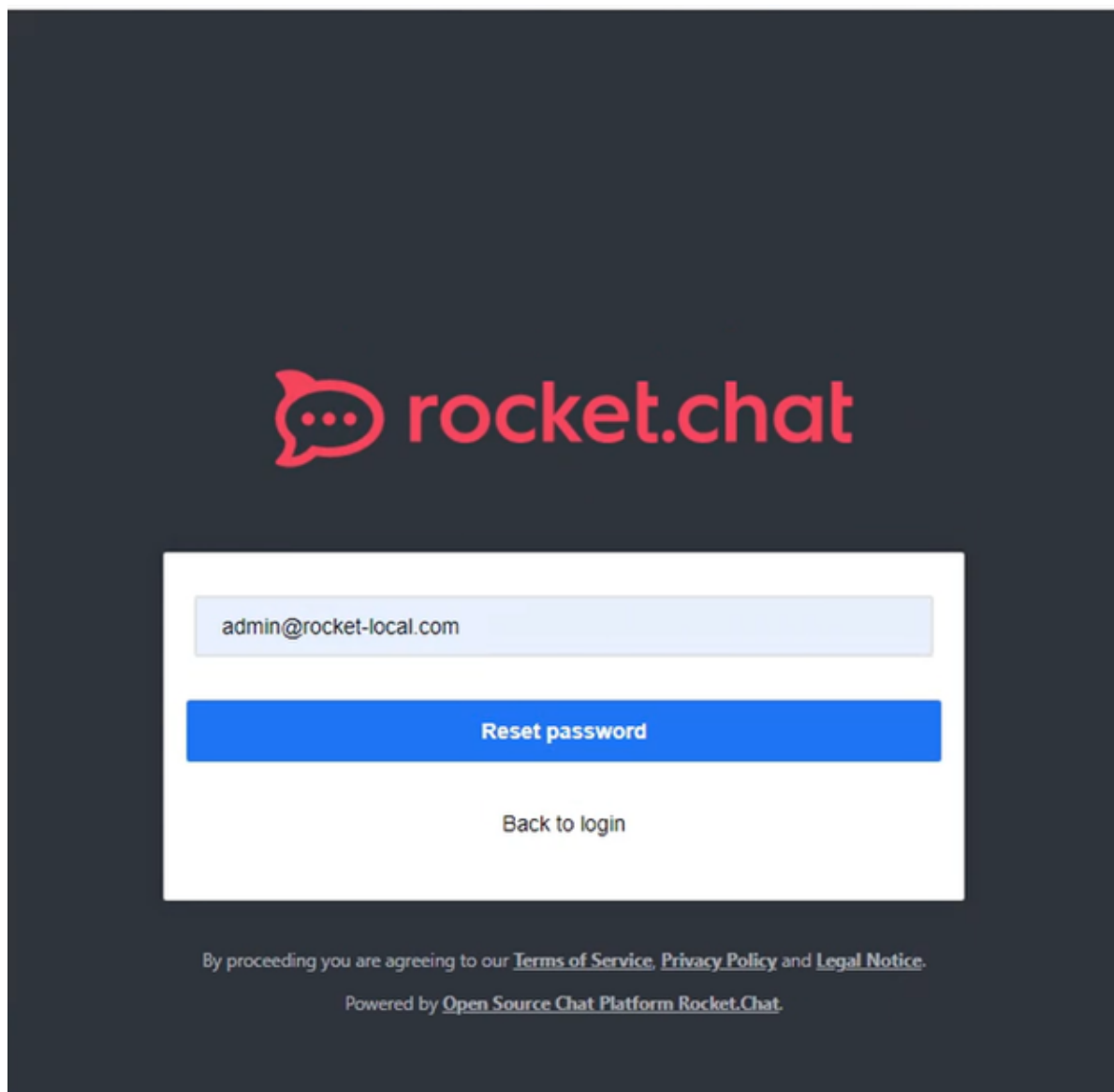


Рис. 3.12: Восстановление пароля

```

Subject: Rocket.Chat - Password Recovery
Message-ID: <d8e0c330-3414-264a-a8ff-c714238b36e3@rocket-local.com>
Date: Sat, 13 Dec 2025 17:22:00 +0000
MIME-Version: 1.0

-----_NmP-aded3d9d2d4c5f9c-Part_1
Content-Type: text/plain
Content-Transfer-Encoding: quoted-printable

Hello,

To reset your password, simply click the link below.

http://10.10.2.22:3000/reset-password/5DCpmrNVefkDd2buG1l7a7NpG\_Rogrdrz5TEZK=tae3N3

Thanks.

-----_NmP-aded3d9d2d4c5f9c-Part_1
Content-Type: text/html; charset=utf-8
Content-Transfer-Encoding: quoted-printable

<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd"><html xmlns="http://www.w3.org/1999/xhtml" style="font-family: -apple-system,BlinkMacSystemFont,'Segoe UI',Roboto,Oxygen,Ubuntu,Cantarell,'Helvetica Neue','Apple Color Emoji','Segoe UI Emoji','Segoe UI Symbol','Meiryo UI',Arial,sans-serif;"><head><!-- If you delete this tag, the sky will fall on your head --><meta name="viewport" content="width=device-width"><meta http-equiv="Content-Type" content="text/html; charset=UTF-8"><title>Rocket.Chat Cloud</title></head><body bgcolor="#F7F8FA" style="font-family: -apple-system,BlinkMacSystemFont,'Segoe UI',Roboto,Oxygen,Ubuntu,Cantarell,'Helvetica Neue','Apple Color Emoji','Segoe UI Emoji','Segoe UI Symbol','Meiryo UI',Arial,sans-serif; width: 100%; height: 100%;"><table class="body" bgcolor="#F7F8FA" width="100%" style="font-family: -apple-system,BlinkMacSystemFont,'Segoe UI',Roboto,Oxygen,Ubuntu,Cantarell,'Helvetica Neue','Apple Color Emoji','Segoe UI Emoji','Segoe UI Symbol','Meiryo UI',Arial,sans-serif; width: 100%; height: 100%;"><tr><td><!-- HEADER --><table class="wrap" bgcolor="#F7F8FA" style="width: 100%; clear: both;"><tr><td class="header container" style="display: block; max-width: 640px; margin: 0 auto; clear: both; border-radius: 2px;"><div class="header-content" style="list-style-position: inside; padding: 16px 0; padding-top: 36px; padding-bottom: 36px; padding-left: 36px; padding-right: 36px; max-width: 640px; margin: 0 auto; display: block;"><table bgcolor="#F7F8FA" width="100%"><tr><td></td></tr></table></div></td></tr></table><!-- /HEADER =

```

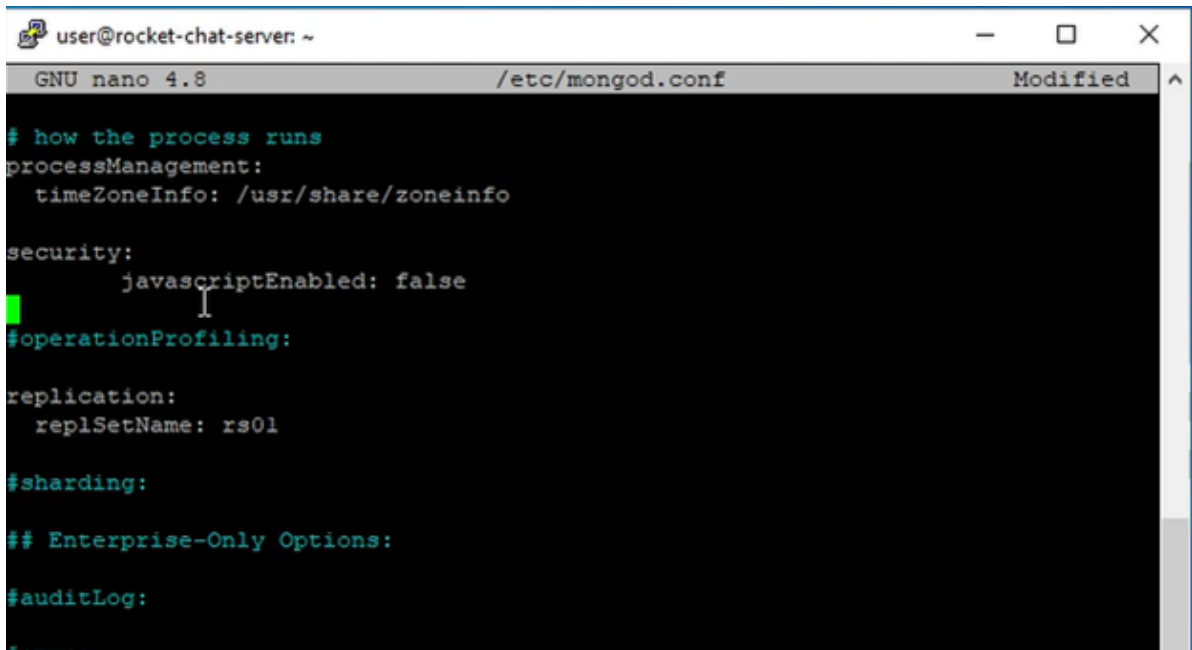
Рис. 3.13: Ссылка для сброса пароля

```
user@rocket-chat-server: ~  
  
You have mail.  
Last login: Sat Dec 13 17:40:26 2025 from 10.10.2.2  
admin@rocket-chat-server:~$ su -user  
Try 'su --help' for more information.  
admin@rocket-chat-server:~$ su - user  
Password:  
user@rocket-chat-server:~$ cd /home  
user@rocket-chat-server:/home$ cat DROP_DB_INFO  
cat: DROP_DB_INFO: No such file or directory  
user@rocket-chat-server:/home$ cd ..  
user@rocket-chat-server:/$ cat backup_codes  
cat: backup_codes: No such file or directory  
user@rocket-chat-server:/$ cat backup_codes  
cat: backup_codes: No such file or directory  
user@rocket-chat-server:/$ cd /home/user/  
user@rocket-chat-server:~$ ls  
backup_codes  
user@rocket-chat-server:~$ cat backup_codes  
backup codes for admin Rocket Chat:  
iFdDR68y kpMifh9E 43PxEyom jho4DGdw RiuwYGrg LohP2b  
rdhcBy8B DvPHRnTz ZZPgeko2  
user@rocket-chat-server:~$
```

Рис. 3.14: back_up коды для двух. аутентификации

Необходимо скопировать ссылку из письма. Нужно обратить внимание, что в терминале при переносе строки используется знак «=», его следует игнорировать. После этого необходимо ввести новый пароль. Для учетной записи администратора Rocket Chat настроена двухфакторная аутентификация при помощи TOTP (Time-based one-time password). Для генерации одноразового пароля необходимо воспользоваться программой KeePass, доступной на машине администрирования (приложение А, стр. 30).

Так как вторая NoSQL-инъекция для повышения привилегий использует высокоуровневый оператор БД \$where, временной, смягчающей мерой, может стать отключение выполнения JavaScript на стороне сервера базы данных. Для этого необходимо отредактировать файл конфигурации БД /etc/mongod.conf, добавив строчку javascriptEnabled: false (рис. 3.15):



```
user@rocket-chat-server: ~
GNU nano 4.8 /etc/mongod.conf Modified
# how the process runs
processManagement:
  timeZoneInfo: /usr/share/zoneinfo

security:
  javascriptEnabled: false

#operationProfiling:

replication:
  replSetName: rs01

#sharding:

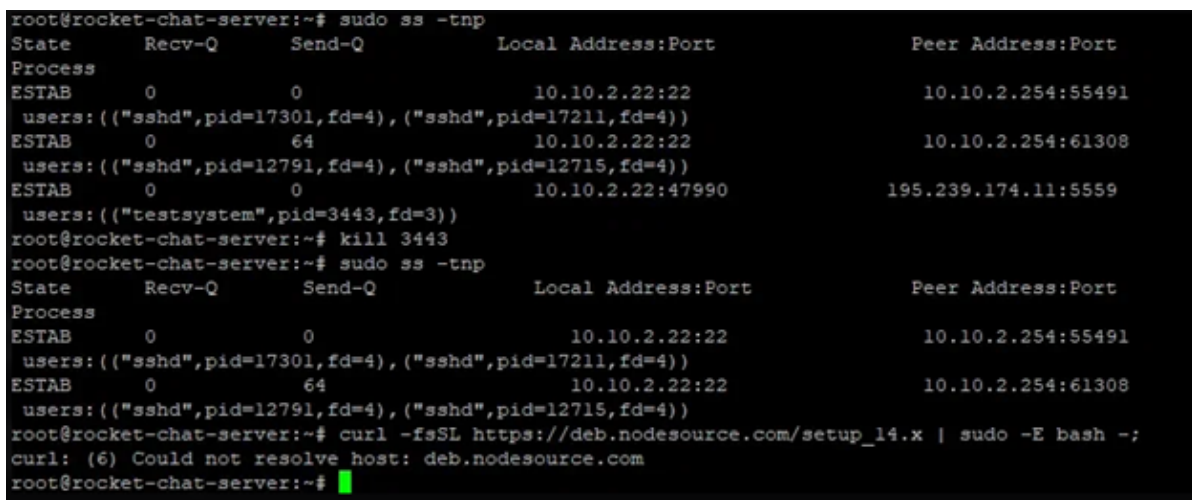
## Enterprise-Only Options:

#auditLog:

#...
```

Рис. 3.15: Настройка конфигурации БД

Удаление соединений. (рис. 3.16):



```
root@rocket-chat-server:~# sudo ss -tnp
State      Recv-Q      Send-Q       Local Address:Port      Peer Address:Port
Process
ESTAB      0            0             10.10.2.22:22            10.10.2.254:55491
  users: (("sshd",pid=17301,fd=4),("sshd",pid=17211,fd=4))
ESTAB      0            64           10.10.2.22:22            10.10.2.254:61308
  users: (("sshd",pid=12791,fd=4),("sshd",pid=12715,fd=4))
ESTAB      0            0           10.10.2.22:47990         195.239.174.11:5559
  users: (("testsystem",pid=3443,fd=3))
root@rocket-chat-server:~# kill 3443
root@rocket-chat-server:~# sudo ss -tnp
State      Recv-Q      Send-Q       Local Address:Port      Peer Address:Port
Process
ESTAB      0            0             10.10.2.22:22            10.10.2.254:55491
  users: (("sshd",pid=17301,fd=4),("sshd",pid=17211,fd=4))
ESTAB      0            64           10.10.2.22:22            10.10.2.254:61308
  users: (("sshd",pid=12791,fd=4),("sshd",pid=12715,fd=4))
root@rocket-chat-server:~# curl -fsSL https://deb.nodesource.com/setup_14.x | sudo -E bash -;
curl: (6) Could not resolve host: deb.nodesource.com
root@rocket-chat-server:~#
```

Рис. 3.16: Удаление соединений

4 Вывод

В ходе выполнения лабораторной работы были изучены и практически освоены методы обнаружения, анализа и устранения сложных многоэтапных кибератак на корпоративную инфраструктуру с использованием учебно-тренировочного комплекса Ampire.

Были исследованы три критические уязвимости в различных компонентах инфраструктуры:

WpDiscuz (CVE-2020-24186) – уязвимость удалённого выполнения кода в плагине WordPress, позволяющая загружать и выполнять произвольные PHP-файлы через функционал комментариев.

Rocket.Chat (CVE-2021-22911, CVE-2022-0847) – комбинация NoSQL-инъекции и уязвимости Dirty Pipe в ядре Linux, приводящая к повышению привилегий и полному компрометированию системы.

Proxylogon (CVE-2021-26855, CVE-2021-27065) – SSRF-уязвимость в Microsoft Exchange Server, позволяющая обходить аутентификацию и загружать веб-шеллы на сервер.

5 Список литературы